Clase guiada de pruebas de seguridad

Actividad 3.1.2 | Campus Abierto | 60 minutos

Durante la clase ejecutarás pruebas de seguridad con la orientación del profesor. Observarás el comportamiento del portal, registrarás evidencias y propondrás mitigaciones. Los comandos y las demostraciones se presentan en clase; este apunte organiza el trabajo y la bitácora.

Preparación y alcance

Trabaja en tu propia instancia Docker, preparada antes del bloque. El único destino autorizado es Campus Abierto en http://localhost:8088. No se incluyen otros equipos, servicios o aplicaciones. Se utilizan cuentas y datos ficticios, pruebas de bajo impacto y el diccionario reducido que indique el profesor.

Comprueba que el portal abra y que el profesor confirme el estado ready. Si falla la preparación, detén las pruebas y solicita ayuda. Los escáneres se ejecutan dentro del entorno Docker de la práctica; conserva las evidencias en student/evidencias.

Minutos	Trabajo guiado
0 a 8	Confirmar entorno, alcance e identidad de cada petición.
8 a 20	Reconocimiento con WPScan y lectura crítica de resultados.
20 a 32	Contraste y confirmación de una hipótesis de inyección.
32 a 43	Prueba inocua de contenido y comparación con un control.
43 a 52	Comprobación de autenticación con una muestra acotada.
52 a 60	Ordenar evidencias, proponer mitigaciones y emitir una decisión.

Qué debes registrar

Guarda un registro por prueba: petición o pasos, identidad utilizada, resultado real, evidencia identificada y recomendación. Separa la observación de la interpretación. Una diferencia de respuesta requiere análisis; un escáner no sustituye tu explicación.

No supongas ejecución remota de código por detectar una versión ni asignes severidad alta a toda enumeración. Registra también resultados negativos o no concluyentes. El profesor mostrará cómo comparar una prueba con un control y cómo limitar el impacto de la demostración.

La preparación de imágenes ocurre antes de clase. No ejecutes extracción de tablas, shells, borrados, diccionarios adicionales ni peticiones a otros destinos. Al finalizar la parte guiada, guarda tus evidencias y sigue la indicación del profesor para preparar el desafío.

Bitácora de la clase

Evidencia propia | Completar durante la demostración

Copia este registro por cada prueba. Puedes usar texto o tabla y adjuntar capturas y archivos. El resultado debe ser Confirmado, No reproducido o No concluyente, con una explicación de la evidencia.

ID y fecha	
Objetivo e hipótesis	
Tipo de prueba y herramienta	
Cuenta y precondiciones	
Petición o pasos realizados	
Comportamiento esperado y fundamento	
Resultado obtenido y estado	
Evidencia identificada	
Impacto y severidad justificados	
Recomendación y prueba de repetición	

Cierre de la práctica guiada

Explica qué confirmó o descartó cada prueba y qué queda sin verificar. Emite GO, NO-GO o GO CON CONDICIONES para el alcance probado. Este ejercicio no certifica la seguridad completa del sistema.

Conserva tus archivos antes de cualquier restablecimiento de la instancia. Abre después el desafío individual y formula tus propias hipótesis. No publiques resultados o evidencias en el repositorio del curso.